

L J INSTITUTE OF COMPUTER APPLICATIONS
Master of Computer Applications (MCA)
Syllabus for Batch - 2025
Semester: III

Category	Discipline Specific Core -III			
Course Title	Ethical Hacking & Penetration Testing			
Scheme and Credits	Theory	Tutorial	Lab	Credits
	3	0	4	5
Pre-requisites (if any)	• CSF & NS (Subject 1) completed or concurrent – understanding of networking, ports, and protocols is essential • Basic Linux CLI navigation (covered in CSF & NS Practical 1 orientation) • Lab machines: Kali Linux + Metasploitable 2 + DVWA on isolated host-only network; Nessus Essentials installed			

1. Course Objectives:

CO1	Explain hacker types, legal frameworks (IT Act, Rules of Engagement), the 5 phases of ethical hacking, the Cyber Kill Chain, and Red/Blue/Purple Team roles.
CO2	Apply passive OSINT and active scanning (Nmap, theHarvester, Shodan) and vulnerability scanning (Nessus) to gather intelligence on authorised targets.
CO3	Execute exploitation and post-exploitation on a lab target using Metasploit and Meterpreter; perform Linux privilege escalation.
CO4	Perform web application penetration testing on DVWA – manually exploit SQLi, Reflected XSS, Stored XSS, and file upload vulnerabilities using Burp Suite.
CO5	Write a complete VAPT report containing Executive Summary, technical findings with CVSS scores, evidence screenshots, and remediation recommendations

L J INSTITUTE OF COMPUTER APPLICATIONS
Master of Computer Applications (MCA)
Syllabus for Batch - 2025
Semester: III

2. Course Contents:

Unit	Course Content	Weightage	Hrs.
Unit I	What is hacking; types of hackers — White Hat, Black Hat, Grey Hat, Hacktivists, Script Kiddies, Nation-State actors; ethical hacking vs malicious hacking; how ethical hacking strengthens security; why companies pay for penetration tests; legal framework — IT Act 2000 (Sections 43, 65, 66B, 66C, 66F); concept of written authorization; Rules of Engagement (RoE); Non-Disclosure Agreements; scope definition; what happens when you test without permission; the 5 Phases of Ethical Hacking — Reconnaissance, Scanning & Enumeration, Gaining Access, Maintaining Access, Covering Tracks; depth at each phase with real-world examples; Cyber Kill Chain mapped to penetration testing phases; how attackers think; how defenders use the Kill Chain to detect and interrupt intrusions at each phase; Red Team vs Blue Team vs Purple Team; VAPT vs Penetration Test vs Vulnerability Assessment — key distinctions; introduction to Penetration Testing Execution Standard (PTES) overview; OWASP Testing Guide v4.2 overview; virtual lab setup overview (Kali Linux, Metasploitable, DVWA).	20%	6
Unit II	Passive reconnaissance — Google Dorking operators (site:, filetype:, intitle:, inurl:, cache:); WHOIS lookups; DNS record types and querying (dig, nslookup — A, MX, NS, TXT, AXFR attempt); Shodan search for exposed services; theHarvester for email and subdomain harvesting; Maltego Community Edition for relationship mapping; LinkedIn OSINT for employee enumeration; Recon-NG framework overview; Nmap scan types — TCP SYN (-sS), TCP Connect (-sT), UDP (-sU), Stealth (-sN/-sF/-sX), Aggressive (-A), version detection (-sV), OS fingerprinting (-O); NSE scripts (--script=vuln, --script=default); timing templates (T0–T5); banner grabbing with Netcat; Network Enumeration — SMB enumeration with enum4linux (-a); SNMP walking concept; SMTP user enumeration via VRFY/EXPN; NetBIOS; Network Scan; reading the report; CVSS v3.1 score components (Attack Vector, Attack Complexity, Privileges Required, User Interaction, Scope, CIA impact); CVE lookup on nvd.nist.gov; differentiating critical/high/medium/low; false positive concept.	20%	8
Unit III	Metasploit Framework architecture — modules (auxiliary, exploit, payload, encoder, nop, post); msfconsole commands	20%	8

L J INSTITUTE OF COMPUTER APPLICATIONS
Master of Computer Applications (MCA)
Syllabus for Batch - 2025
Semester: III

	(search, use, show options, set, run, back, sessions); LHOST/LPORT/RHOST/RPORT variables; payloads — staged (windows/meterpreter/reverse_tcp) vs stageless (windows/shell_reverse_tcp — single self-contained); MSFvenom for payload generation; listener setup with multi/handler Meterpreter commands (sysinfo, getuid, ps, download, upload, shell, migrate, hashdump, run post/multi/recon/local_exploit_suggester); Privilege Escalation — Linux: checking sudo -l, finding SUID binaries (find / -perm -4000 -type f 2>/dev/null), GTF0Bins usage; exploiting an SUID binary step-by-step; reading /etc/shadow after root Privilege Escalation; Windows: unquoted service paths, weak registry permissions, token impersonation concept (getsystem); Password Attacks — identifying hash types; John the Ripper dictionary attack with rockyou.txt; Hashcat (identify and cracking by mode); Hydra online brute force against SSH and HTTP login forms.		
Unit IV	OWASP Top 10 walkthrough with attack scenarios and defence for each: A01 Broken Access Control (IDOR demonstration); A02 Cryptographic Failures (cleartext credentials); A03 Injection — SQLi (manual injection, UNION-based extraction), Command Injection; A04 Insecure Design; A05 Security Misconfiguration (default credentials, directory listing); A06 Vulnerable Components (known CVEs in libraries); A07 Identification & Authentication Failures; A08 SSRF; Burp Suite Community Edition — configuring browser proxy (FoxyProxy); Proxy intercept (intercept on/off, forward, drop); Repeater (resending and modifying requests); Intruder (Sniper attack for credential stuffing, payload lists); Decoder; Target scope configuration; SQL injection on DVWA (Low and Medium security); manual error-based SQLi; UNION-based column enumeration (ORDER BY, UNION SELECT null); extracting database names, table names, and data; Medium security bypass via Burp Repeater; POST modification; Cross-Site Scripting on DVWA — Reflected XSS (Low and Medium), basic <script> alert, Medium filter bypass with case variation; Stored XSS — posting a persistent script that fires for all visitors; XSS cookie theft concept; DOM-based XSS overview; File upload vulnerability (DVWA); uploading a PHP webshell on Low security; why file type validation matters; Medium security bypass concept; CSRF concept and demonstration; broken authentication (DVWA brute force module with Burp Intruder).	25%	8
Unit V	Penetration test report structure — Cover Page (tester, date, target, scope, classification); Executive Summary (1 page non-	15%	6

L J INSTITUTE OF COMPUTER APPLICATIONS
Master of Computer Applications (MCA)
Syllabus for Batch - 2025
Semester: III

	technical — what was found, overall risk, top 3 recommendations); Scope & Methodology (tools used, testing approach, timeframe); Technical Findings section — each finding includes: title, severity (CVSS v3.1 score + qualitative rating Critical/High/Medium/Low/Informational), Affected System/Component, Vulnerability Description, Proof of Concept / Evidence (screenshot), Business Impact, Remediation Recommendation, Reference (CVE number or CWE where applicable); CVSS v3.1 Base Score calculation walked through with examples; calculating score for a typical backdoor (network exploitable, no auth, full C/I/A); calculating score for a stored XSS (network, low complexity, user interaction, partial impact); compare and justify severity ratings; Risk Heat Map; plotting findings by likelihood vs impact; Remediation strategies — patching, secure configuration, principle of least privilege, input validation, output encoding; VAPT deliverable; Professional ethics — responsible disclosure process; bug bounty platforms (HackerOne, Bugcrowd); never testing without written permission; protecting client data; Certification pathways — CompTIA Security+ (entry); CEH (EC-Council); eJPT (eLearnSecurity beginner); OSCP (OffSec advanced); how this course content maps to each.		
--	--	--	--

Program Outcomes (POs)

PO Code	Program Outcomes
PO1	Computational Knowledge
PO2	Problem Analysis
PO3	Design and Development of Solutions
PO4	Modern Tool Usage
PO5	Individual and Team Work
PO6	Professional Ethics
PO7	Communication Skills
PO8	Life-long Learning

L J INSTITUTE OF COMPUTER APPLICATIONS

Master of Computer Applications (MCA)

Syllabus for Batch - 2025

Semester: III

CO-PO Mapping Matrix

Mapping Scale:

- 3 = High
- 2 = Moderate
- 1 = Low

COs \ POs	PO1	PO2	PO3	PO4	PO5	PO6	PO7	PO8
CO1	3	2	2	3	1	3	1	2
CO2.	2	3	3	3	2	2	1	2
CO3	2	3	3	3	2	2	1	2
CO4	2	3	3	3	2	2	2	2
CO5	2	2	2	2	3	3	3	3

List of Practicals (sample)

Lab: Kali Linux (attacker) and Metasploitable 2 + DVWA (targets) on isolated host-only network.
 Nessus Essentials installed on Kali.

Practical 1 – Lab Setup & OSINT Reconnaissance (Est. time: 3 hrs)

Objective: Verify lab environment isolation, confirm all tools are functional, and perform passive OSINT reconnaissance on a simulated target.

Environment: Kali Linux, Metasploitable 2

Tools: ifconfig, nmap, Firefox, theHarvester, dig, WHOIS

Expected output: Both VM IPs documented; DVWA working screenshot; theHarvester output; DNS records table; zone transfer result (success or failure with reason).

Observation questions: (1) Why does a successful DNS zone transfer represent a security risk? (2) From the LinkedIn OSINT results, what information could an attacker use for a spear-phishing attack?

Practical 2 – Active Scanning and Vulnerability Assessment (Est. time: 4 hrs)

Objective: Conduct comprehensive Nmap scanning against Metasploitable 2 and run a Nessus vulnerability scan; build a prioritised finding list.

Environment: Kali Linux to Metasploitable 2

Tools: nmap, Nessus Essentials

Observation questions: (1) Nessus gives you CVSS 9.8 for a finding. Does that automatically make it your top priority? What other factors matter? (2) What is the difference between a vulnerability scan and a penetration test?

Practical 3 – Exploitation with Metasploit Framework (Est. time: 5 hrs)

Objective: Gain a Meterpreter shell on Metasploitable 2 using a known exploit; execute post-exploitation commands.

Environment: Kali Linux to Metasploitable 2

L J INSTITUTE OF COMPUTER APPLICATIONS

Master of Computer Applications (MCA)

Syllabus for Batch - 2025

Semester: III

Tools: msfconsole

Expected output: Screenshot of Meterpreter prompt showing target hostname; /etc/passwd downloaded; hashdump output; local_exploit_suggester output.

Observation questions: (1) The vsftpd 2.3.4 backdoor was introduced maliciously into the source code. What does this tell us about supply chain security? (2) Your Meterpreter shell runs as the daemon user. Why is it important to escalate to root before post-exploitation?

Practical 4 – Linux Privilege Escalation (Est. time: 4 hrs)

Objective: Escalate from a low-privilege shell to root using SUID binary and sudo misconfiguration techniques.

Environment: Kali Linux to Metasploitable 2 or faculty-provided Ubuntu VM with planted misconfigurations

Tools: msfconsole for initial access; find, sudo, bash, GTF0Bins (browser reference)

Expected output: sudo -l screenshot; SUID binary list; GTF0Bins page referenced; id showing root; /etc/shadow first 3 lines; backdoor user creation confirmation.

Observation questions: (1) Why is giving a regular user sudo privileges to a text editor like vim a critical security mistake? (2) What is the /etc/shadow file and why does reading it represent a significant post-exploitation win for an attacker?

Practical 5 – Web App Testing: SQL Injection on DVWA (Est. time: 5 hrs)

Objective: Manually exploit SQL Injection at Low and Medium security levels on DVWA using Burp Suite; extract database contents.

Environment: Kali Linux; DVWA at <http://192.168.x.target/dvwa>

Tools: Burp Suite Community Edition, Firefox (Burp proxy configured via FoxyProxy)

Expected output: Error message confirming SQLi; UNION SELECT result showing DB version; users table dump with hashed passwords; Burp Repeater screenshot for Medium bypass.

Observation questions: (1) The passwords you extracted are MD5 hashes. Why is MD5 insufficient for password storage? What should be used instead? (2) How would a parameterised query prevent SQL injection?

Practical 6 – Web App Testing: XSS and File Upload on DVWA (Est. time: 4 hrs)

Objective: Demonstrate Reflected XSS, Stored XSS, and file upload vulnerabilities on DVWA at Low and Medium security levels.

Environment: Kali Linux; DVWA; Burp Suite Community

Tools: Burp Suite, Firefox DevTools

Expected output: Reflected XSS alert screenshot (Low and Medium bypass); Stored XSS cookie alert screenshot; PHP webshell command execution screenshot; attack chain summary.

Observation questions: (1) What is Content Security Policy (CSP) and how does it defend against XSS? (2) The file upload vulnerability allowed a PHP webshell. List 3 server-side controls that would have prevented this.

Practical 7 – Password Cracking and Hydra Brute Force (Est. time: 4 hrs)

Objective: Crack password hashes using John the Ripper and Hashcat; perform online brute force against DVWA login with Hydra.

Environment: Kali Linux; Metasploitable 2; DVWA

Tools: john, hashcat, hydra, /usr/share/wordlists/rockyou.txt

Expected output: John --show output with cracked passwords; Hashcat session screenshot; Hydra SSH success screenshot; Hydra HTTP form success screenshot; time comparison table.

L J INSTITUTE OF COMPUTER APPLICATIONS

Master of Computer Applications (MCA)

Syllabus for Batch - 2025

Semester: III

Observation questions: (1) Why does adding a salt to a password hash dramatically increase cracking time even with the same dictionary? (2) From a defender's perspective, what detection rule in Splunk would alert on an SSH brute force attack?

Practical 8 – Putting It Together: Mini VAPT Assessment (Est. time: 5 hrs)

Objective: Conduct a mini end-to-end penetration test against Metasploitable 2 following the 5-phase methodology and document findings in a structured format ready for the capstone report.

Environment: Kali Linux to Metasploitable 2 + DVWA

Tools: All tools used in Practicals 1-7

Expected output: Completed finding sheet with 5 documented vulnerabilities; all screenshots labelled; CVSS scores calculated; ready for capstone expansion.

Observation questions: (1) You found 12 vulnerabilities. The client says they can fix only 3 this month. How do you decide which 3 to recommend? (2) What is the difference between a grey-box and a black-box penetration test, and when would you choose each?

Capstone – Full VAPT Report (Weeks 11-13, 12 hrs)

Objective: Expand Practical 8 into a complete, professionally structured penetration test report for a simulated client engagement.

Deliverable: Cover page – Executive Summary (1 page, non-technical) – Scope & Methodology – Technical Findings (minimum 6 findings, each with all required fields) – Risk Heat Map – Remediation Priority Table – Conclusion.

Assessment: 30 marks – Finding quality and evidence (15), Report structure and writing (10), CVSS accuracy (5).

Reference Books:

1. "Penetration Testing: A Hands-On Introduction to Hacking" – Georgia Weidman, No Starch Press
2. "Metasploit: The Penetration Tester's Guide" – David Kennedy et al., No Starch Press
3. "The Web Application Hacker's Handbook" – Stuttard & Pinto, Wiley
4. "Hacking: The Art of Exploitation" – Jon Erickson, No Starch Press
5. OWASP Testing Guide v4.2 – <https://owasp.org>